

Chaper 1. Overview of Information Systems Security



Chapter 1. Overview of Information System Safety and Security

Information systems security encompasses the **protection** of **digital assets, data,** and **infrastructure** from **unauthorized access,** use, disclosure, disruption, **modification,** or **destruction.** In today's interconnected digital landscape, where organizations rely heavily on technology for operations, communication, and **data management, security** has evolved from a technical concern to a fundamental business imperative.

This course examines the comprehensive framework of **information security,** exploring core **security requirements** that form the foundation of **protective measures,** identifying diverse **threats** targeting **IT infrastructure,** and analyzing **security assurance models** that organizations deploy to maintain robust **defensive postures** in an increasingly hostile **cyber environment.**

Agenda

Chapter 1: Overview of Information System Security

Information Security

- What is Information Security?
- The Importance of Information Security
- Components of Information Security

Information Systems Security

- Components of an Information System
- What is Information Systems Security?

Security Requirements for Information Systems

- Confidentiality
- Integrity
- Availability

Seven IT Infrastructure Domains and Threats

- The Seven IT Infrastructure Domains
- Threats and Risks

Model for Ensuring Information Systems Security

- Introduction
- Some Information Systems Security Models

Review Questions

End-of-chapter review and self-assessment questions

What is Information Security?

What is Information Security?

Information Security is the practice of protecting information from **unauthorized access, use, disclosure, modification, or destruction**.

"**Information security** protects the **confidentiality, integrity, and availability** attributes of information assets during **storage, processing, and transmission**."

— *Principles of Information Security*

Two Key Definitions

SANS Institute Definition

Information Security is the protection against unauthorized:

- **Access** to information systems
- **Use** of sensitive data
- **Disclosure** of confidential information
- **Modification** of critical data
- **Destruction** of information assets

Academic Definition

Information Security safeguards three core attributes of information assets:

- **Confidentiality** — Preventing **unauthorized disclosure**
- **Integrity** — Ensuring accuracy and completeness
- **Availability** — Maintaining reliable access

These attributes must be protected throughout the information lifecycle: during **storage, processing, and transmission**.

- ❑ Both definitions emphasize that **information security** is a comprehensive practice requiring protection across multiple dimensions—from preventing **unauthorized** actions to maintaining the fundamental **CIA Triad** properties.

The CIA Triad

Foundation of Information Security

The **CIA Triad** represents the three fundamental principles that guide **information security** practices and decision-making across all organizational levels. These principles serve as evaluation criteria for **security measures** and help organizations prioritize **security investments** based on their specific needs and **risk profiles**.

Confidentiality

Ensures that information is accessible only to **authorized individuals**, systems, or processes. Protects sensitive data from **unauthorized disclosure** through **encryption**, **access controls**, and **classification schemes**.



Integrity

Guarantees that information remains **accurate, complete, and unaltered** except by **authorized parties**. Maintains **data trustworthiness** through **checksums**, **digital signatures**, and **version control** mechanisms.

Availability

Ensures that information and systems are accessible to **authorized users** when needed. Maintains **operational continuity** through **redundancy**, **backup systems**, and **disaster recovery planning**.

The CIA Triad: Core Security Objectives



Confidentiality

Preventing **unauthorized disclosure** of sensitive information. Data should only be readable by **authorized** subjects.



Integrity

Preventing **unauthorized modification** of data and system state. Changes must be controlled and **auditable**.



Availability

Preventing **denial of service attacks** that disrupt legitimate system operations and resource access.

These three objectives form the foundation of **security** goals. **Operating systems** must support all three dimensions simultaneously because resources are shared across multiple users and processes. Weakness in any area compromises overall **system security**.

Confidentiality in Practice

Real-World Examples

File System Protection: Personal documents should only be accessible to their owner. Operating system **file permissions** enforce **read restrictions** based on **user identity**.

Process Isolation: Applications cannot peek into **memory spaces** of other processes. **Address space separation** and **hardware memory management** prevent **unauthorized reads**.

Defense Layers: **Encryption** provides **data-at-rest protection**, while **permission systems** control **access**. These complementary mechanisms create robust **confidentiality** protection.

Integrity in Practice

Preventing Unauthorized Changes

System Configuration: Only authorized processes with elevated privileges can modify critical system settings. Tampering with **boot parameters** or **service configurations** requires explicit permission.

Data Protection: **Audit logs** must resist tampering to maintain their evidentiary value. **Financial transaction records** require **write protection** to prevent **fraud**. **System binaries** need **integrity checks** to detect **malware** injection.

Integrity controls require both **write access restrictions** and **validation mechanisms**. The OS must verify that modifications come from legitimate sources and meet defined constraints.

Availability in Practice

Resource Limitation

Imposing **CPU quotas**, **memory limits**, and **I/O throttling** prevents single processes from monopolizing **system resources** and degrading performance for others.

DoS Prevention

Operating systems must defend against **fork bombs**, **file descriptor exhaustion**, and **disk space attacks** that aim to make the system unresponsive.

Management Tools

Scheduling algorithms, **resource quotas**, and **process limits** (**ulimit**, **cgroups**) ensure fair **resource allocation** and system responsiveness under load.

Availability means the system remains functional and responsive. Without proper **resource management**, malicious or buggy processes can render the entire system unusable.

Information Security

IS = Information Technology Security + Information Assurance

IT Security

IT Security focuses on the protection of **systems, networks, and data** from **attacks**, damage, or **unauthorized access**. It emphasizes **preventive measures, detection capabilities**, and immediate **response to threats**.

Key activities include implementing **firewalls, antivirus software, intrusion detection systems, access controls**, and **security patches**. The primary goal is to prevent **security breaches** and minimize **vulnerabilities** in technical infrastructure.

Information Assurance

Information Assurance takes a broader perspective, ensuring that information remains **available**, maintains **integrity**, and can be **recovered** following disruptions. It encompasses **business continuity planning, disaster recovery**, and long-term **strategic security management**.

Example: Implementing **offsite backup systems** exemplifies **information assurance**—even if primary systems are compromised, organizational operations can continue and data can be restored, ensuring **business resilience** beyond immediate **security controls**.

Key Concepts in Information Security (3A)

Access

The ability and means to communicate with or interact with a system, resource, or **data**. Access can be **physical** (entering a server room) or **logical** (logging into a database). Controlling **access** is fundamental to all **security models**.

Asset

Any resource of value to an organization that requires **protection**. Assets include **hardware, software, data, intellectual property, reputation, and personnel**. Proper **asset identification** and **classification** drive **security prioritization** decisions.

Attack

Any attempt to destroy, expose, alter, disable, steal, or gain **unauthorized access** to information or systems. **Attacks** can be **malicious** or accidental, **external** or **internal**, and vary widely in sophistication and impact.

Types of Security Attacks

Security attacks are categorized along multiple dimensions that help **security professionals** understand **threat** patterns, develop appropriate **countermeasures**, and allocate defensive resources effectively. Understanding these classifications enables organizations to design targeted **security architectures**.

Attack Type	Characteristics	Examples
Active Attack	Modifies data or disrupts systems; detectable but difficult to prevent	Malware injection, denial-of-service , data modification
Passive Attack	Monitors or records data without modification; difficult to detect	Eavesdropping , traffic analysis , password sniffing
Direct Attack	Targets systems immediately without intermediaries	Brute-force login attempts, SQL injection
Indirect Attack	Uses intermediary systems or social engineering	Phishing , supply chain compromise , watering hole attacks

Real-World Security Incidents



Insider Threat

A trusted employee with legitimate access credentials exfiltrates proprietary **customer data** to sell to competitors. These incidents are particularly damaging because **insiders** bypass **perimeter defenses** and possess knowledge of **security weaknesses**, making detection challenging and impact severe.



Unauthorized Access

External attackers exploit **unpatched vulnerabilities** in **web applications** to gain **administrative access** to corporate databases. This common scenario highlights the importance of timely **patch management** and continuous **vulnerability assessment** in maintaining security posture.



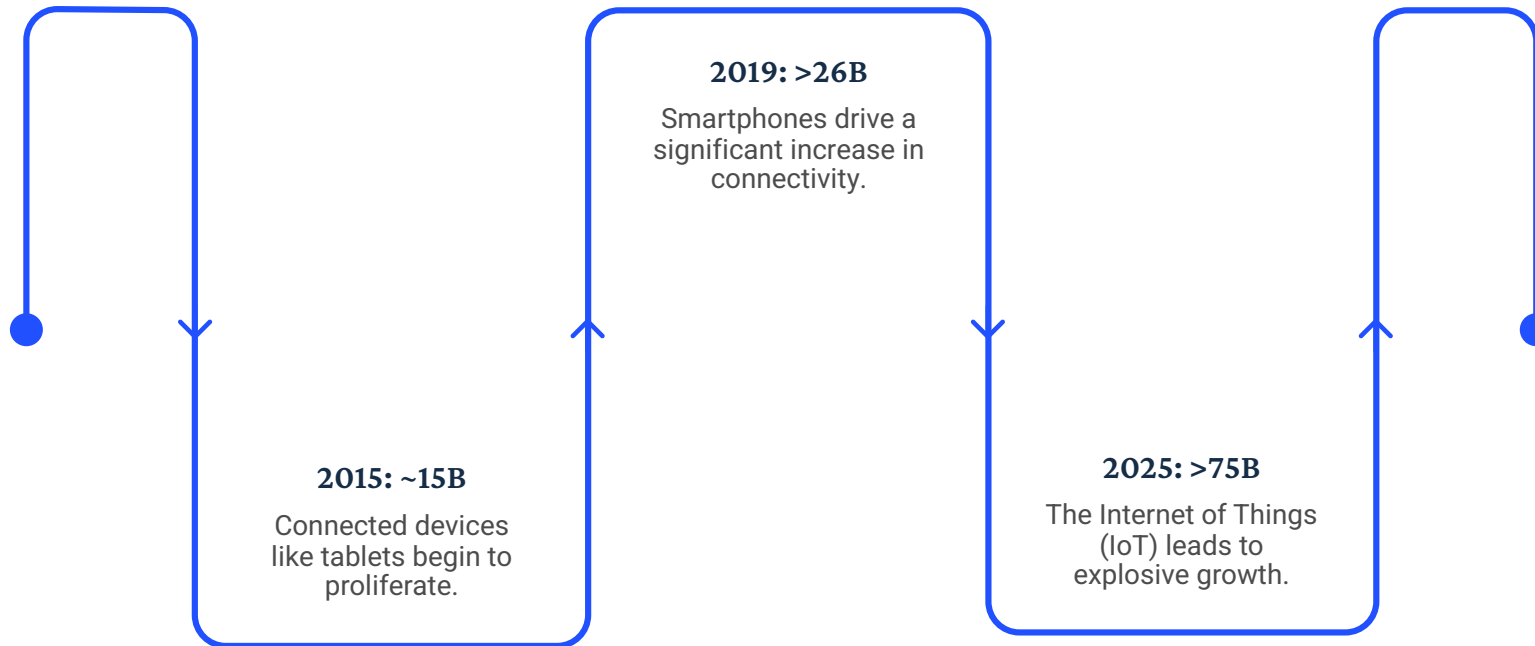
Data Breach

Misconfigured **cloud storage buckets** expose millions of customer records, including **personally identifiable information** and **financial data**. Such incidents demonstrate that security failures often stem from **human error** and **configuration mistakes** rather than sophisticated attacks.

Why Information Security is Critical?

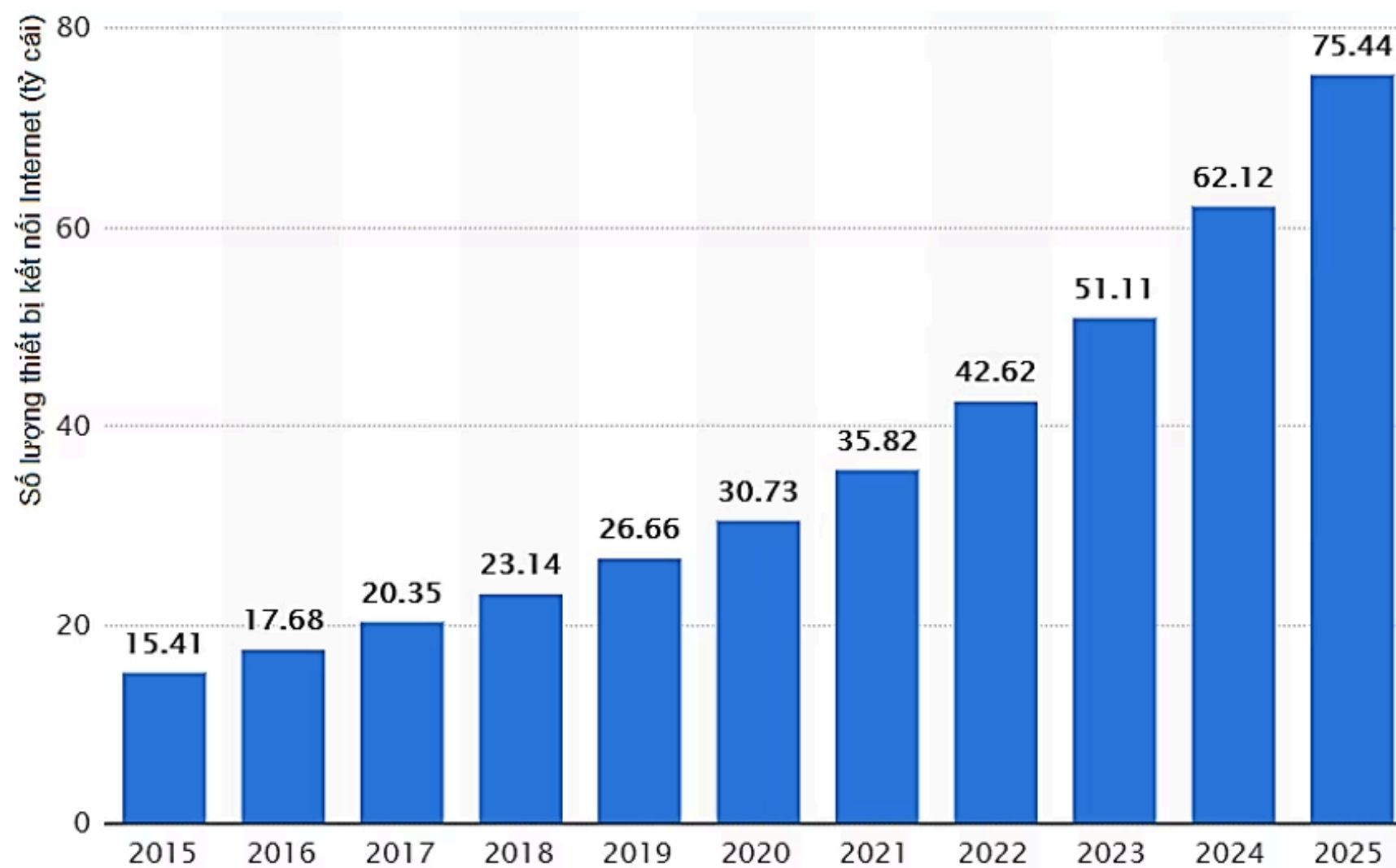
Explosive Growth of Connected Devices

In recent years, alongside the rapid development of **mobile devices** and especially **IoT devices**, the number of **Internet users** and devices connected to the Internet has grown dramatically. According to statistics and forecasts from **Statista**, the number of **Internet-connected devices** was approximately **15 billion** in 2015, increased to over **26 billion** in 2019, and is projected to surge to over **75 billion** by 2025.



Smart IoT connected devices form the foundation for developing many critical applications across various sectors of society, including:

- **Smart cities**
- **Smart communities**
- **Smart homes**
- **Health monitoring** and care applications



. Thống kê và dự báo số lượng các thiết bị **IoT** kết nối **Internet** từ 2015 đến 2025 (theo Statista)

Security Incidents: The Dark Side of Connectivity

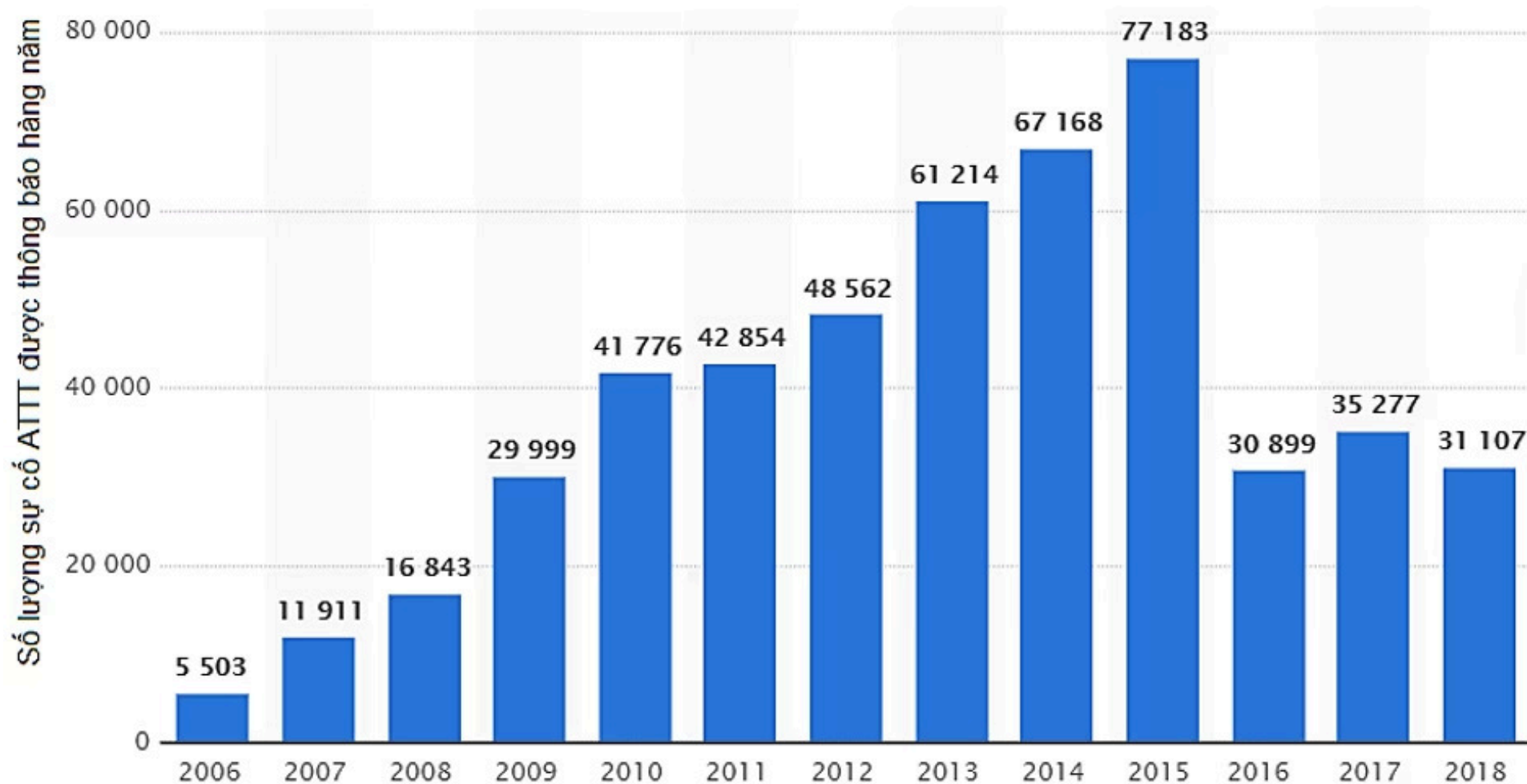
Alongside the tremendous benefits that Internet-connected devices bring, **security incidents** affecting computer systems, smartphones, **IoT devices**, and users have also surged dramatically.

According to **Statista** statistics, the number of **security incidents** reported by U.S. federal government agencies during the 2006-2015 period increased sharply, from 5,503 incidents in 2006 to 77,183 incidents in 2015.

However, during 2016-2018, the number of **security incidents** decreased significantly to only 31,107 incidents in 2018.

Key Insights:

- **14x increase** in incidents from 2006 to 2015
- Peak of **77,183 incidents** in 2015
- Significant decline to **31,107** by 2018
- Reflects both improved **detection** and evolving **threat landscape**



Hình 1.3. Số lượng sự cố mất **ATTT** báo cáo bởi các cơ quan chính phủ Hoa Kỳ giai đoạn 2006-2018 [3]

Cybersecurity Losses in Vietnam

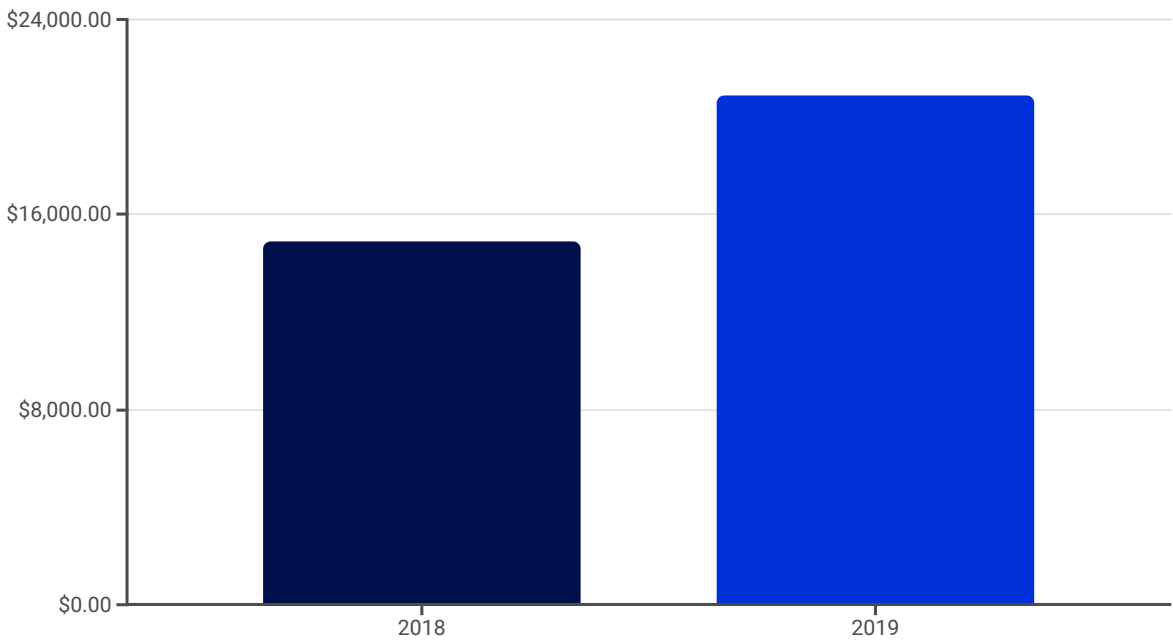
Escalating Financial Impact

According to the Vietnam **Cybersecurity** Summary 2019 report by Bkav, the estimated **damage** from **cybersecurity incidents** in Vietnam reached 20,892 billion VND (approximately 902 million USD) in 2019, representing a sharp increase from 14,900 billion VND in 2018.

Key Statistics:

- **2018 Losses:** 14,900 billion VND
- **2019 Losses:** 20,892 billion VND (~902 million USD)
- **Year-over-year increase:** 40.3%

This dramatic escalation demonstrates that **cyber threats** are growing rapidly in both frequency and financial impact, affecting businesses, individuals, and **national security**.



Financial losses due to cybersecurity incidents in Vietnam from 2018 to 2019

Why Information Security is Critical

Information security has become critical due to several converging factors that create an increasingly complex **threat** landscape:

Explosive Device Growth

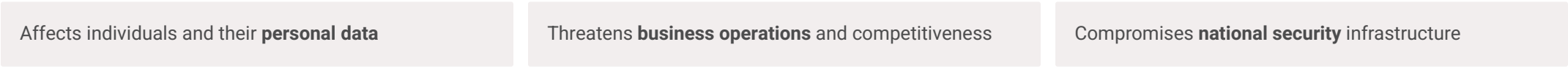
The proliferation of Internet-connected devices—smartphones, tablets, **IoT** sensors, wearables, and smart appliances—creates an exponentially expanding **attack surface** that organizations must defend.

Increasingly Sophisticated Malware

Modern cyber **threats** have evolved far beyond simple viruses:

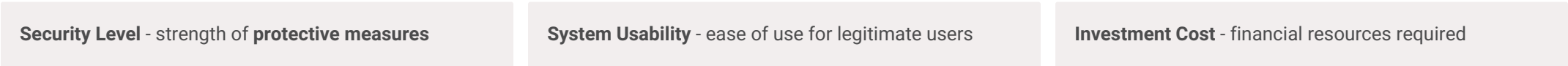
- **APT (Advanced Persistent Threat)** attacks - targeted, long-term intrusions
- **Fileless malware - attacks** that operate in memory without leaving traces
- **Ransomware - encryption**-based extortion
- **Botnets** - coordinated networks of compromised devices
- **Cryptocurrency mining malware** - resource hijacking

Impact Scope



The Security Triangle

Effective **security** requires a delicate balance between these three competing factors to achieve optimal **protection** without hindering legitimate use or exceeding budget constraints.



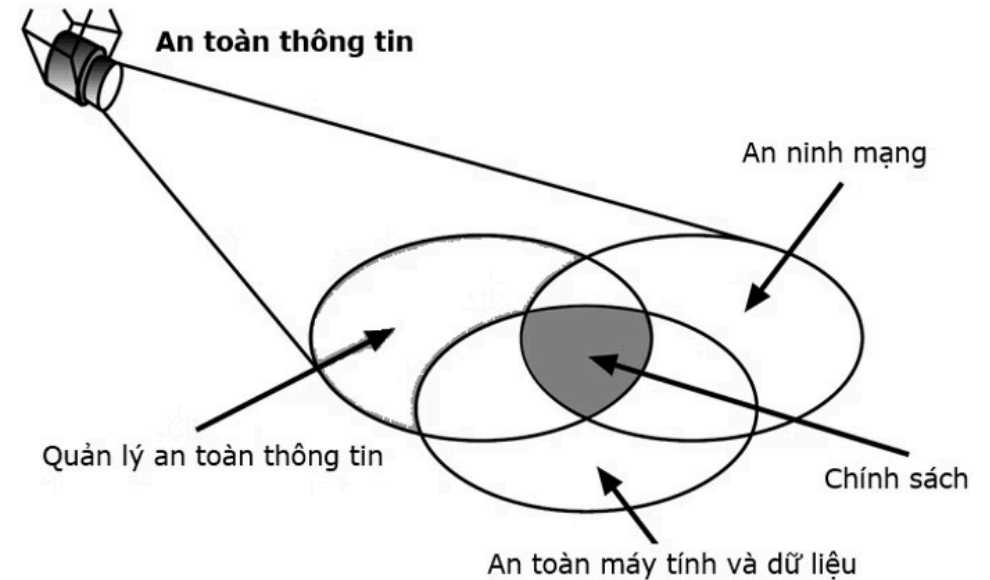
Component of Information Security

Three Components of Information Security

Information security can be divided into **three** main components that work together to protect organizational assets. These components are interconnected and overlap, with **security policy** serving as the common foundation that unifies all three areas.

- *An toàn máy tính và dữ liệu* (Computer & data security)
- *An ninh mạng* (Network security)
- *Quản lý an toàn thông tin* (Management of information security)

These three components have close relationships and intersect with each other, with the common element being **information security policy** that serves as the foundation for all **security** efforts.



Computer and Data Security

Computer and Data Security refers to protecting computer **hardware**, **software**, and **stored data** to ensure systems operate securely and meet user requirements.

Objectives

- Protect system resources from **unauthorized access**
- Ensure reliable and secure system operation
- Safeguard sensitive and critical data



Operating System Security

Hardening OS configurations, disabling unnecessary services, implementing **security patches** promptly, and configuring system-level **access controls**



Malware Protection

Deploying **antivirus software**, **endpoint detection and response** systems, and **application whitelisting** to prevent and detect **malicious code**



Access Control

Implementing **authentication** mechanisms, **authorization** policies, and the principle of **least privilege** to ensure users access only necessary resources



Backup and Recovery

Implementing regular **backup** procedures, testing **restoration** processes, and maintaining offline copies to ensure **data availability** following **incidents**



Encryption

Protecting **data at rest** and **data in transit** using **cryptographic algorithms** to render information unreadable to **unauthorized** parties

Network Security

Network Security ensures the protection of **network infrastructure** and **data transmitted** across networks against **attacks** and **unauthorized access**

Perimeter Controls

- **Firewalls, Proxy:** Filter **network traffic** based on **security rules**, blocking **unauthorized access** attempts
- **Virtual Private Networks (VPN):** Create **encrypted tunnels** for secure remote access
- **SSL/TLS: Encrypt** web communications to protect **data in transit**

Detection and Response

- **Intrusion Detection Systems (IDS):** Monitor **network traffic** for suspicious patterns and known **attack signatures**
- **Intrusion Prevention Systems (IPS):** Actively block detected **threats** in real-time
- **Network Monitoring:** Continuous analysis of traffic patterns to identify **anomalies**

Information Security Management

Information security management involves **overseeing** and **supervising** the implementation of **security measures** to enhance their effectiveness. It provides the organizational framework necessary to maintain a robust **security posture** across all domains.



Risk Management

The core foundation of **security management**, focusing on identifying, assessing, and mitigating **information security risks**. **Risk assessment** plays a pivotal role in determining **security priorities**.



Security Standards

Establishing and maintaining **compliance** with industry standards and frameworks (**ISO 27001**, **NIST**, etc.) that guide **security practices** and ensure consistent implementation.



Security Policies

Developing comprehensive **security policies** that define **security requirements**, acceptable use, **incident response** procedures, and **governance** structures across the organization.



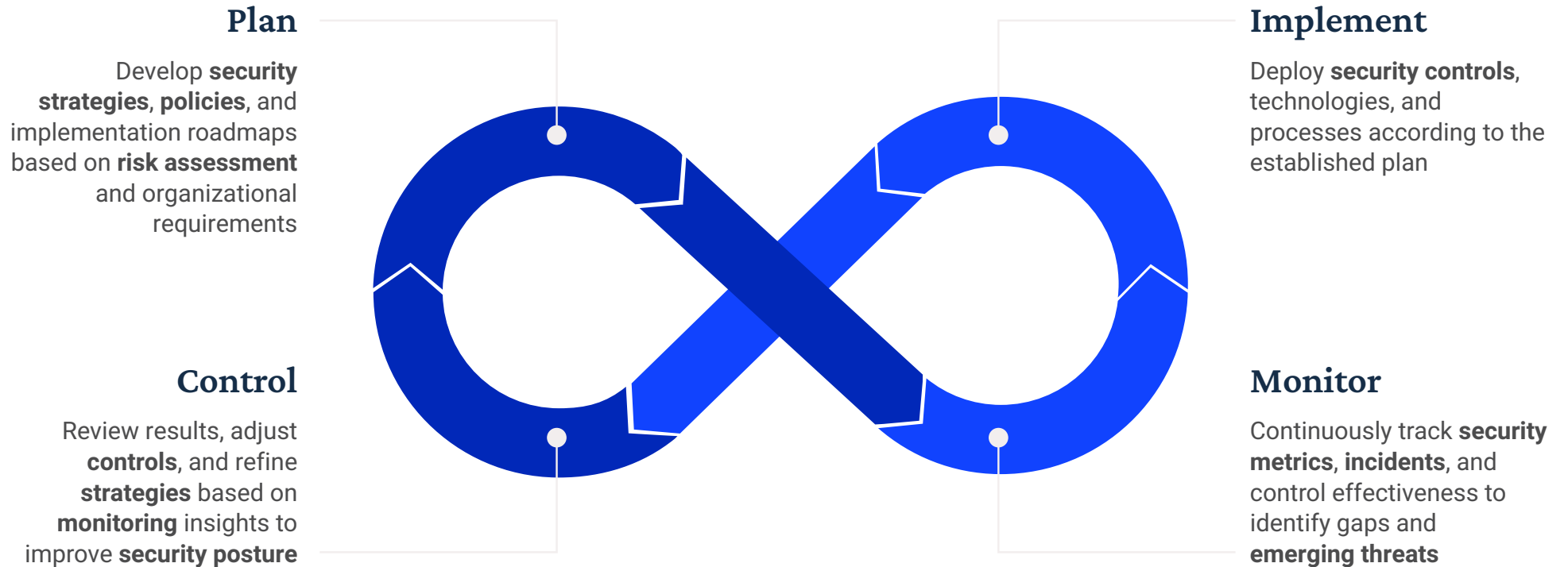
Training & Awareness

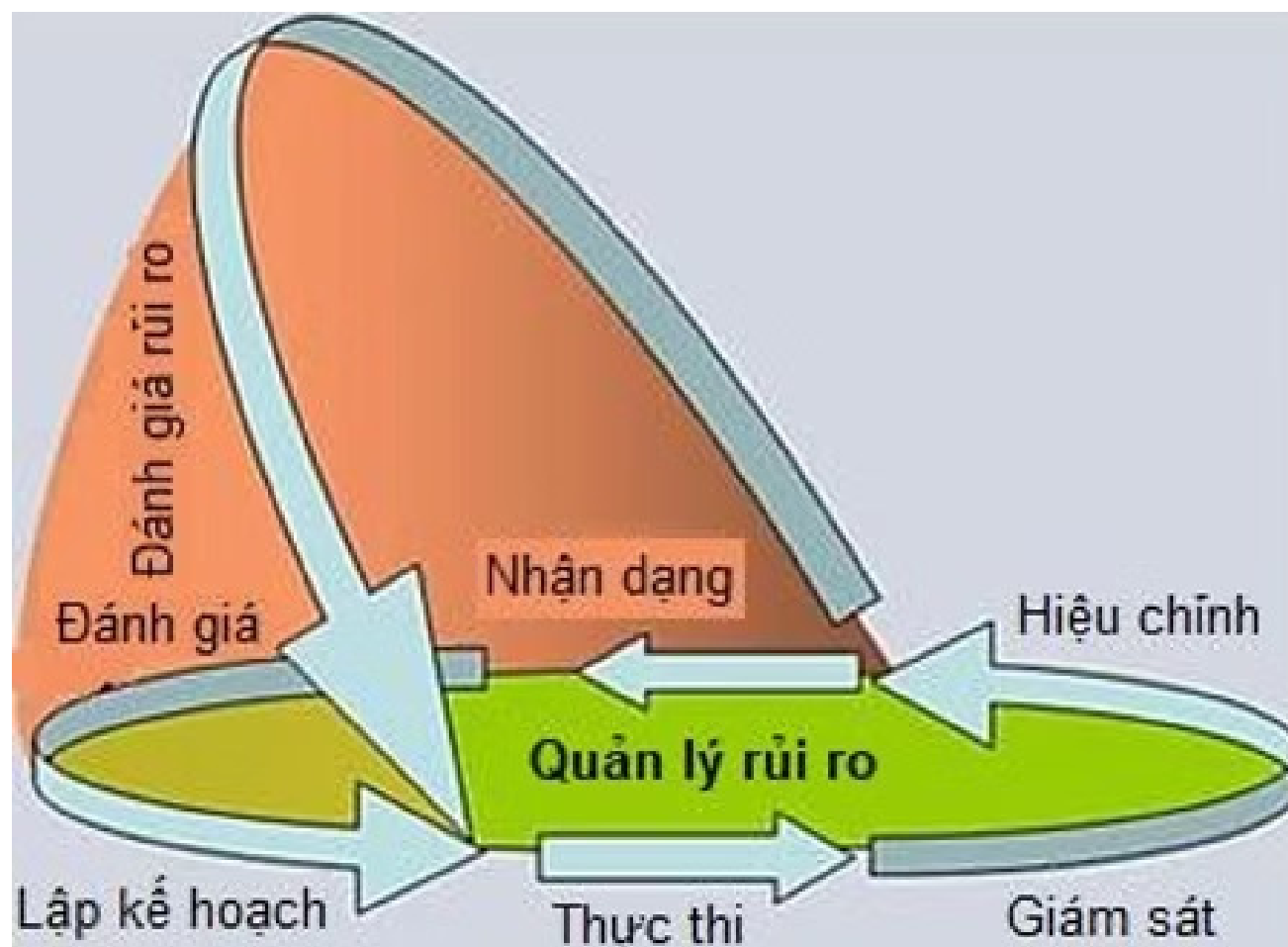
Educating users and raising **security awareness** throughout the organization to create a **security-conscious culture** and reduce **human-related vulnerabilities**.

Effective **information security management** integrates these elements into a cohesive program that continuously monitors, evaluates, and improves **security measures** to address evolving **threats** and business requirements.

Continuous Management Cycle

Information security management must be implemented through a continuous, iterative cycle that adapts to changing internal and external conditions over time. This cyclical approach ensures **security measures** remain effective and relevant.





Information Security Management Cycle

Three Layers of Information Security Policy

Information security policy consists of rules and regulations established by an organization to ensure **security measures** are implemented and enforced. These policies form a comprehensive framework that addresses security at multiple levels.



Policy Example: Strong Authentication

❏ **Example:** To enhance **information system security**, organizations can implement **strong authentication policies** using **biometric** characteristics instead of traditional passwords. For example:

- **Fingerprint authentication** for data center **access control** systems
- **Biometric** login for computer systems and applications
- **Multi-factor authentication** combining biometrics with other credentials

This approach significantly strengthens security by replacing easily compromised passwords with unique biological identifiers that cannot be easily stolen or replicated.

Information Systems Security

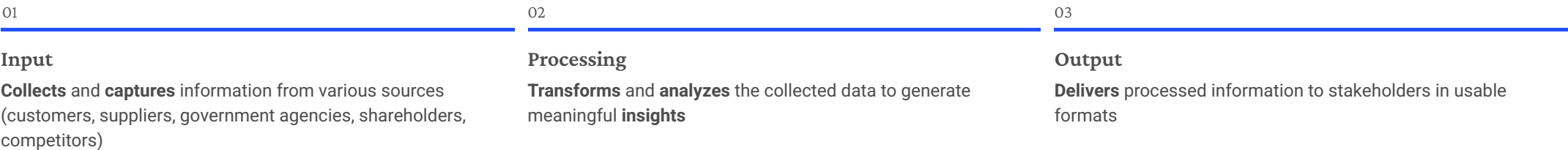
Components of an Information System

What is an Information Systems?

An **information system** is an **integrated system** of components designed to **collect, store, process, and deliver information, knowledge, and digital products**. In the **digital economy**, **information systems** play a critical role in the **operations** of organizations, agencies, and enterprises.

The Information System Model

Every **information system** consists of three main **components** that work together in a continuous cycle:

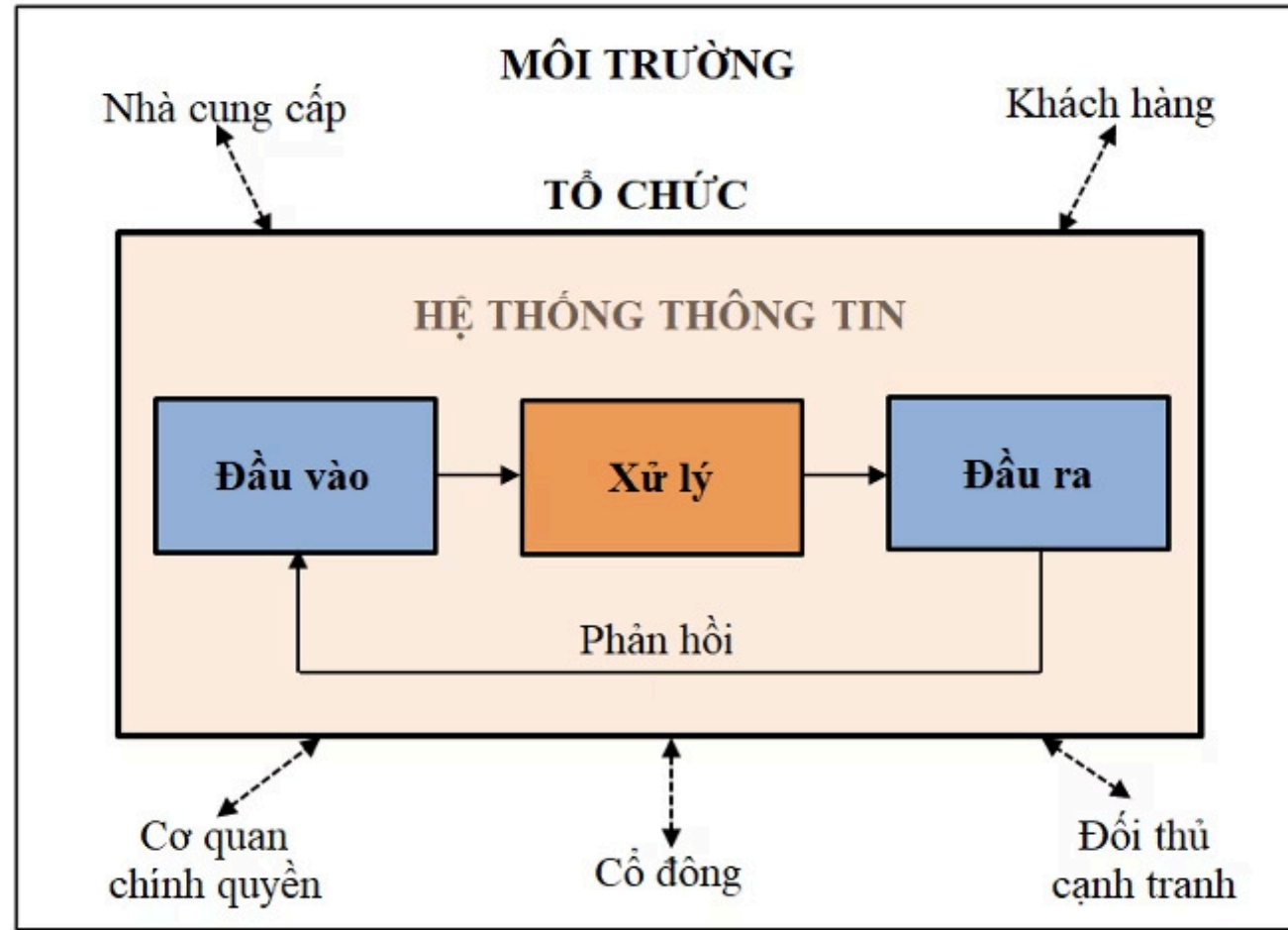


❏ **Feedback mechanisms** ensure continuous improvement and **system refinement**

Common Information System Examples

- **Enterprise Resource Planning (ERP) systems** – Integrate **business processes** across departments
- **Search engines** – Enable **information discovery** and **retrieval**
- **Geographic Information Systems (GIS)** – Manage and analyze **spatial data**
- **Customer Relationship Management (CRM)** – Track **customer interactions** and sales

Information systems enable organizations to interact effectively with customers, suppliers, government agencies, shareholders, and competitors, forming the **backbone of modern business operations**.



Information System Model of an Organization

Computer-Based Information System Components

Modern **information systems** integrate multiple technological and organizational elements that work together to support business processes. Each component presents unique **security challenges** and requires specific protective measures.



Hardware

Physical computing devices including **servers**, workstations, **network equipment**, and **storage systems** that require **physical security** and maintenance



Software

Operating systems, applications, and utilities that must be **patched**, configured **securely**, and protected from **malicious code**



Database

Organized data repositories requiring **access controls**, **encryption**, **backup procedures**, and **integrity** verification



Network

Communication infrastructure enabling data transmission that needs **firewalls**, **encryption**, and **intrusion detection**



Procedures

Documented processes and **policies** guiding system operation, **incident response**, and user behavior

What is Information Systems Security?

Information Systems Security is the practice of ensuring the **security properties** of an **information system**, including **confidentiality**, **integrity**, and **availability**.

The **CIA triad** provides the fundamental framework for defining **security requirements** across all information systems. Every **security control**, **policy**, and **architectural decision** should directly support one or more of these core principles. Organizations prioritize these requirements differently based on their specific missions, **risk tolerances**, and **regulatory obligations**.

Different systems emphasize different aspects of **CIA**. **Financial systems** prioritize **integrity** and **availability**, **healthcare systems** balance all three equally, and **military systems** often emphasize **confidentiality** above other concerns.

Confidentiality Requirements

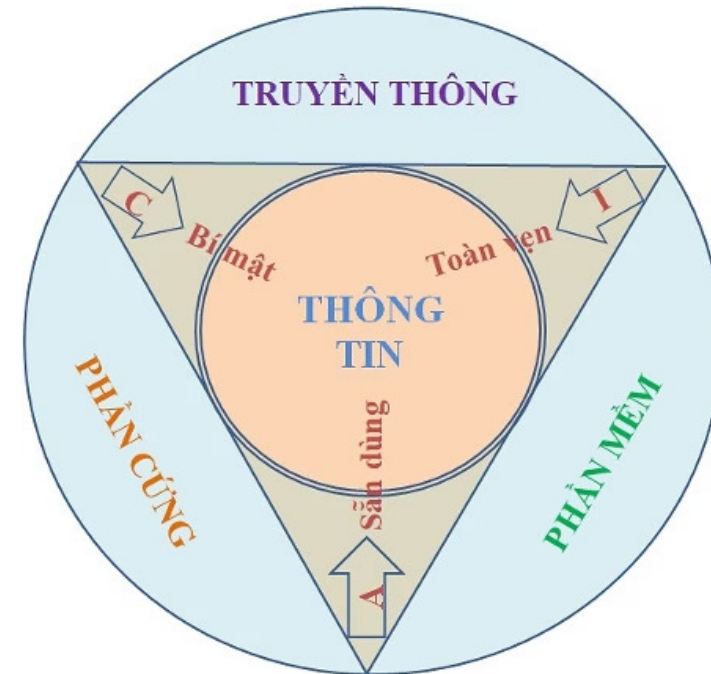
Ensuring **sensitive information** remains private and accessible only to **authorized entities** through **encryption**, **access controls**, and **data classification**

Integrity Requirements

Maintaining **accuracy** and **trustworthiness** of information throughout its lifecycle via **validation checks**, **audit trails**, and **change management**

Availability Requirements

Guaranteeing reliable access to information and systems when needed through **redundancy**, **backup systems**, and **business continuity planning**



Components of an Information System and Information Systems Security

Security Requirements for Information Systems

Confidentiality

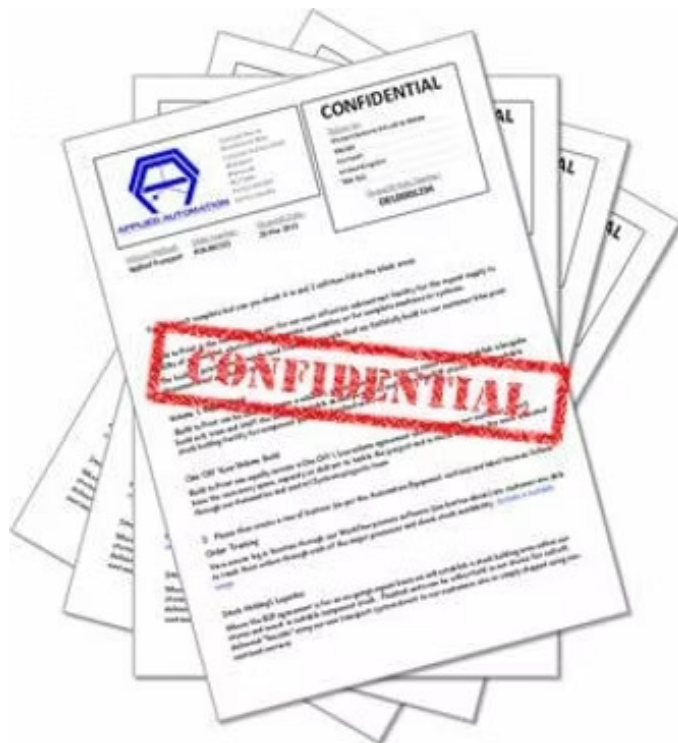
Confidentiality ensures that **sensitive information** is accessible only to **authorized** individuals or systems, protecting against **unauthorized disclosure** whether intentional or accidental. This principle becomes increasingly critical as organizations collect vast amounts of personal, financial, and proprietary data subject to **regulatory requirements** and competitive pressures.

Technical Controls

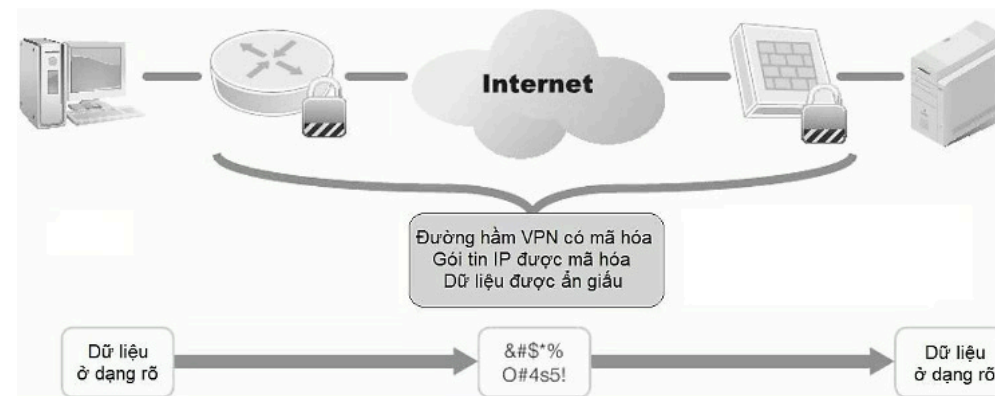
- **Encryption:** Transforms data into unreadable format using **cryptographic algorithms** (AES, RSA)
- **Access Control Lists (ACLs):** Specify which users can access specific resources
- **Virtual Private Networks (VPN):** Create secure tunnels for **data transmission** over untrusted networks
- **Data Loss Prevention (DLP):** Monitors and blocks **unauthorized data transfers**

Administrative Controls

- **Data Classification:** Categorize information by **sensitivity level** to guide **protection requirements**
- **Need-to-Know Principle:** Limit **access** to only information required for job functions
- **Non-Disclosure Agreements:** Legal contracts binding parties to maintain **confidentiality**
- **Security Clearances:** Formal **authorization** processes for accessing **classified information**



A document marked “Confidential”



Ensuring confidentiality through a VPN tunnel or encryption

Integrity: Ensuring Data Trustworthiness

Integrity guarantees that information remains **accurate**, **complete**, and **unaltered** except through **authorized processes**. This principle is fundamental to maintaining **trust** in **information systems**—if users cannot rely on **data accuracy**, the system loses its value regardless of **confidentiality** or **availability**.

1

Hash Functions

Generate unique **digital fingerprints** for files, enabling detection of **unauthorized modifications**. Any change to the file produces a completely different **hash value**, making **tampering** evident.

2

Digital Signatures

Provide **authentication** and **non-repudiation** by **cryptographically** binding documents to their creators. Recipients can verify both the **sender's identity** and that content hasn't been **altered**.

3

Version Control

Track all changes to documents and code, maintaining complete **audit trails** showing who modified what and when, enabling **rollback** to previous versions if needed.

4

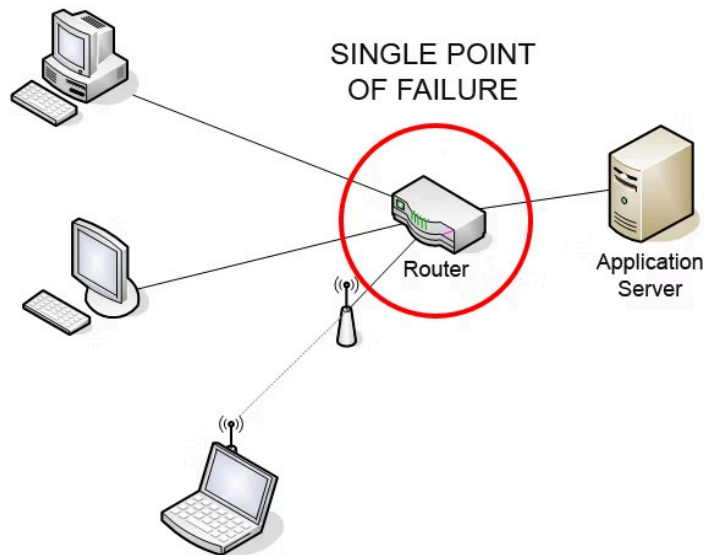
Input Validation

Verify that data entering systems meets expected formats and ranges, preventing **injection attacks** and ensuring only **valid information** is processed.

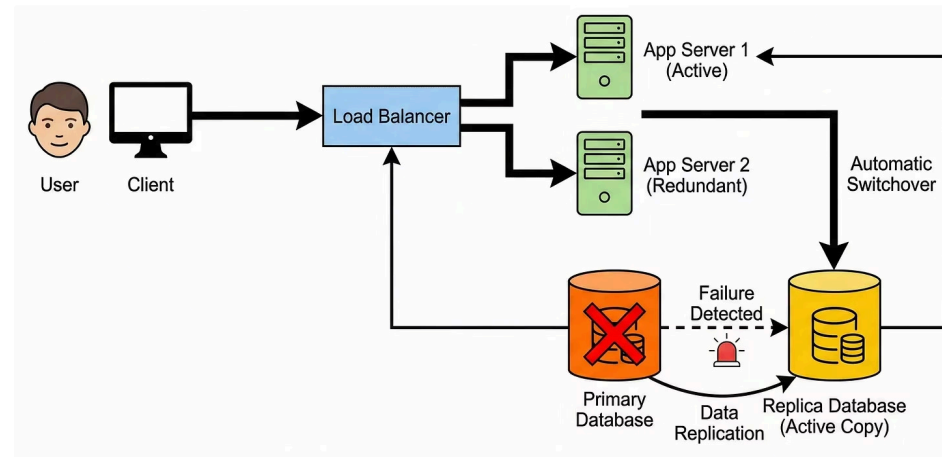
Availability Architecture Comparison

Single Point of Failure vs Redundant Design

System architecture profoundly impacts **availability**. **Single points of failure** create **vulnerability** where one component failure brings down the entire system, while **redundant architectures** distribute functions across multiple components that can compensate for failures.



Redundancy can be implemented at multiple levels: **hardware redundancy** (RAID arrays, redundant power supplies), **network redundancy** (multiple internet connections, load balancers), **geographic redundancy** (data centers in different regions), and **data redundancy** (real-time replication). Each level adds cost but improves **resilience** against different **failure** types.



Measuring System Availability

Availability is quantified using precise metrics that inform **service level agreements** and guide **infrastructure investments**. Understanding these measurements helps organizations set realistic expectations and prioritize improvement efforts.

Availability Formula

$$A = \frac{\text{Uptime}}{\text{Uptime} + \text{Downtime}} \times 100\%$$

Expressed as percentage, with **99.9%** ("**three nines**") representing approximately **8.7 hours downtime** annually

MTBF

Mean Time Between Failures: Average operational time between system **failures**. Higher **MTBF** indicates more **reliable systems** requiring less frequent repairs.

MTTR

Mean Time To Repair: Average time required to restore **system functionality** after **failure**. Lower **MTTR** minimizes **downtime** impact on operations.

Availability Level	Downtime/Year	Downtime/Month	Typical Use Case
99% (Two nines)	3.65 days	7.2 hours	Internal tools
99.9% (Three nines)	8.7 hours	43.2 minutes	Business applications
99.99% (Four nines)	52.6 minutes	4.3 minutes	Critical systems
99.999% (Five nines)	5.3 minutes	26 seconds	Mission-critical infrastructure

Availability: Maintaining Service Continuity

Availability ensures that **information systems** and data remain accessible to **authorized users** whenever needed. In today's always-on business environment, **system downtime** directly translates to lost revenue, damaged reputation, and **regulatory penalties**. Organizations increasingly recognize availability as a **competitive differentiator**.

Threats to availability range from **hardware failures** and **software bugs** to deliberate **denial-of-service attacks** and **natural disasters**. Protecting availability requires **redundant systems**, **proactive maintenance**, **monitoring**, and comprehensive **disaster recovery planning** that addresses diverse **failure scenarios**.

Organizations must balance **availability requirements** against costs—achieving higher availability demands exponentially greater investment. The appropriate **availability level** depends on **business criticality**, customer expectations, and **regulatory requirements** specific to each system.

IT Infrastructure

The Seven IT Infrastructure Domains

The seven-domain IT infrastructure model provides a structured approach to understanding organizational technology environments and identifying domain-specific **security requirements**. Each domain presents unique **vulnerabilities** and requires tailored **security controls**.

Understanding these seven domains helps organizations systematically identify **vulnerabilities**, implement appropriate **controls**, and ensure comprehensive **security** coverage across the entire IT infrastructure.



User Domain

Includes all users (employees, customers, visitors) who **access** the organization's systems. Encompasses user accounts, **access credentials**, and human behavior patterns.



Workstation Domain

Comprises desktop computers, laptops, and workstations where users perform daily tasks. **Security** focuses on **endpoint protection**, **configuration management**, and local **data security**.



LAN Domain

The local area network connecting workstations and servers within organizational facilities. Includes switches, access points, and internal **network infrastructure**.



LAN-to-WAN Domain

The critical boundary connecting the internal LAN to external wide area networks. Includes **firewalls**, routers, and **perimeter security controls**.



WAN Domain

Wide area networks including the Internet and cloud services that connect geographically distributed locations and enable external communications.



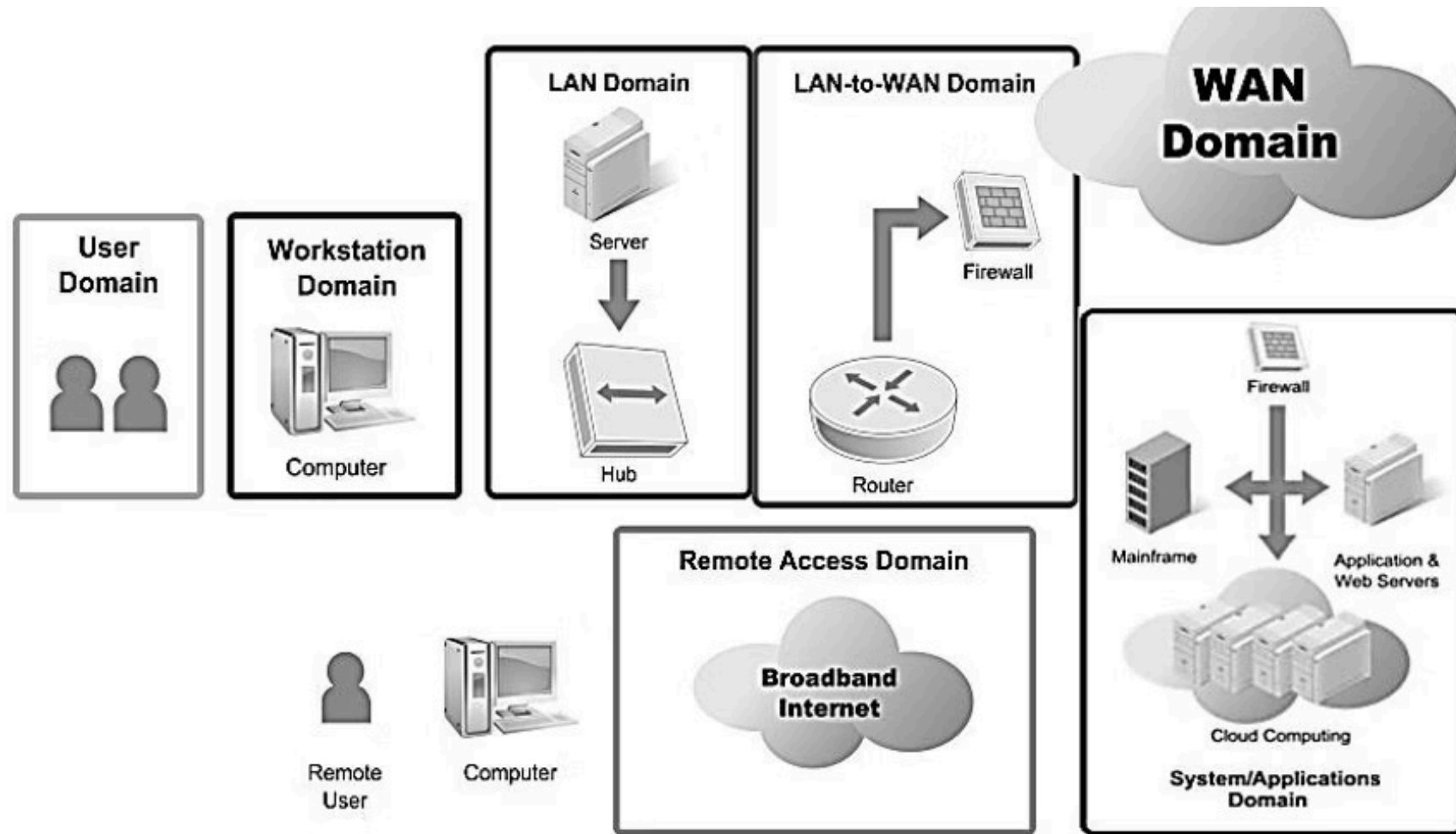
Remote Access Domain

Infrastructure supporting remote workers connecting to organizational resources from external locations via **VPN**, remote desktop, or cloud applications.



System/Application Domain

Servers, databases, web applications, email systems, DNS, and other critical services that provide business functionality and store organizational **data**.



Seven Domains in IT Infrastructure Based on Network Connectivity Levels

1. User Domain Threats

The **User Domain**, encompassing all individuals with system access, consistently represents the most **vulnerable** element in IT infrastructure. Human behavior is inherently unpredictable and difficult to control through technical measures alone, making this domain particularly challenging to secure.

Insider Threats

Malicious employees or contractors with legitimate **access credentials** intentionally compromise data, steal **intellectual property**, or sabotage systems. These **threats** are particularly dangerous because insiders understand **security measures** and possess **authorized access**.

Social Engineering

Attackers manipulate users into divulging sensitive information or performing actions that compromise **security**. **Phishing** emails, pretexting phone calls, and physical tailgating exploit human psychology rather than technical **vulnerabilities**.

Human Error

Accidental **misconfigurations**, clicking malicious links, using **weak passwords**, or improperly handling **sensitive data** create unintentional **security breaches**. Studies show human error contributes to the majority of **security incidents**.

Policy Violations

Users circumventing **security policies** for convenience—sharing **passwords**, disabling **security software**, using unauthorized applications—undermine **technical controls** and create exploitable **vulnerabilities**.

2. Workstation Domain Threats

Workstations serve as the primary interface between users and organizational systems, making them frequent **attack** targets. These **endpoints** often contain **sensitive data** and provide pathways into broader **networks**, requiring comprehensive **protection** strategies.

Common Threats

- **Malware Infections:** **Viruses, trojans, ransomware, and spyware** that compromise workstation integrity and steal data
- **Unauthorized Software:** Users installing unapproved applications that may contain **vulnerabilities** or **malicious code**
- **Physical Theft:** Lost or stolen devices exposing organizational data if not properly **encrypted**

Protection Measures

- **Endpoint Protection:** **Antivirus, EDR** systems, and **application whitelisting**
- **Patch Management:** Regular OS and application updates to address known **vulnerabilities**
- **Full Disk Encryption:** Protecting data if devices are lost or stolen
- **Configuration Management:** Standardized, hardened system configurations

3. LAN and 4. LAN-to-WAN Domain Threats

Local Area Networks (LANs) connect workstations and servers within organizational facilities, while **LAN-to-WAN** connections form the critical boundary between internal networks and the internet. Both domains present significant **security challenges** requiring **layered defenses**.

Network Intrusions

Unauthorized access to network resources through exploitation of **vulnerabilities** in **network protocols**, services, or devices. Attackers who penetrate the **network perimeter** gain access to internal systems and data.

Packet Sniffing

Interception of unencrypted **network traffic** allowing attackers to capture passwords, sensitive data, and confidential communications transmitted across the network without proper **encryption**.

Router and Switch Vulnerabilities

Network infrastructure devices often run outdated **firmware** with known **security flaws**. Compromised network equipment enables **traffic manipulation**, **denial of service**, and pivot points for attacking other systems.

Firewall Misconfigurations

Improperly configured **firewalls** may allow **unauthorized traffic** or block legitimate communications. Regular **firewall rule reviews** and **change management** processes are essential for maintaining proper **network segmentation**.

5. WAN, 6. Remote Access, and 7. System/Application Domain Threats

Wide Area Networks, remote access infrastructure, and system/application domains face sophisticated **threats** from internet-connected adversaries. These domains require robust **security architectures** that balance accessibility with protection against external **threats**.

Denial of Service Attacks

Distributed Denial of Service (**DDoS**) **attacks** overwhelm systems with traffic from multiple sources, rendering services unavailable. Modern **DDoS attacks** can generate hundreds of gigabits per second, requiring specialized **mitigation** services.

Brute-Force Attacks

Automated attempts to guess **passwords** through systematic trial of possible combinations. **Remote access** services are particularly vulnerable, necessitating **multi-factor authentication** and **account lockout** policies.

Cloud Vulnerabilities

Misconfigured **cloud storage**, inadequate **access controls**, and **shared responsibility** confusion create exposures in cloud environments. Organizations must understand their **security** obligations versus cloud provider responsibilities.

Application Exploits

Web applications and databases contain **vulnerabilities** like **SQL injection**, **cross-site scripting**, and **authentication bypass** that attackers exploit to gain **unauthorized access** or execute **malicious code**.

Defence in Depth Strategy

Defence in Depth Strategy

The **Defence in Depth** model is a comprehensive **security** approach that creates multiple **layers of protection**, ensuring that if one layer fails, others remain to defend the system. This strategy recognizes that no single **security control** is perfect, so **layered defenses** provide resilience against sophisticated **attacks**.

According to this model, organizations should establish multiple **protective layers** with varying capabilities and characteristics. The strength of **Defence in Depth** lies in its diversity—different layers protect against different **threats**, and attackers must overcome multiple obstacles rather than a single barrier.



Usability

Design **security layers** that protect without creating excessive friction for legitimate users, maintaining productivity while ensuring safety



Cost-Effectiveness

Balance **security** investments across layers to achieve optimal protection within budget constraints, prioritizing **controls** based on **risk assessment**.



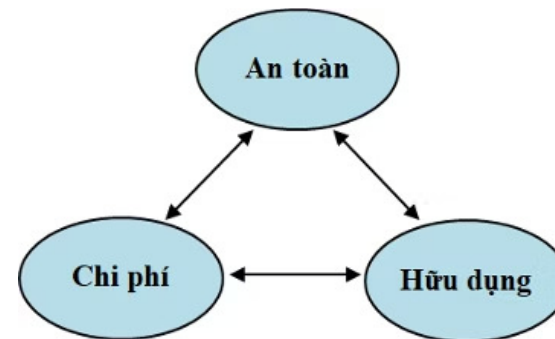
Security

Implement varied **security controls** across different layers (technical, administrative, physical) so that a **vulnerability** in one does not compromise the entire system.

Key Considerations

A critical aspect of implementing **Defence in Depth** is remembering the triangle of **Security-Cost-Usability**

- Increasing **security** strength often increases costs and reduces usability
- Improving usability may reduce **security** or increase implementation costs
- Reducing costs typically requires compromises in **security** strength or user experience



Organizations must carefully balance these factors based on their **risk tolerance**, **regulatory requirements**, and business objectives. The goal is not maximum **security** at any cost, but rather appropriate **security** that enables business operations while managing **risks** to acceptable levels.

Security-Cost-Usability Balance

Effective **security** requires balancing three competing factors: **security strength**, implementation costs, and system **usability**. Organizations cannot maximize all three simultaneously—improving **security** often reduces **usability** or increases costs, while cost reduction may weaken **security** or frustrate users.

High Security

Multi-factor authentication, biometric scanning, and strict **access controls** provide strong protection but increase costs and reduce convenience for legitimate users.

Low Cost

Simple **password authentication** minimizes expenses and maintains **usability** but provides weaker **security** vulnerable to **compromise**.

High Usability

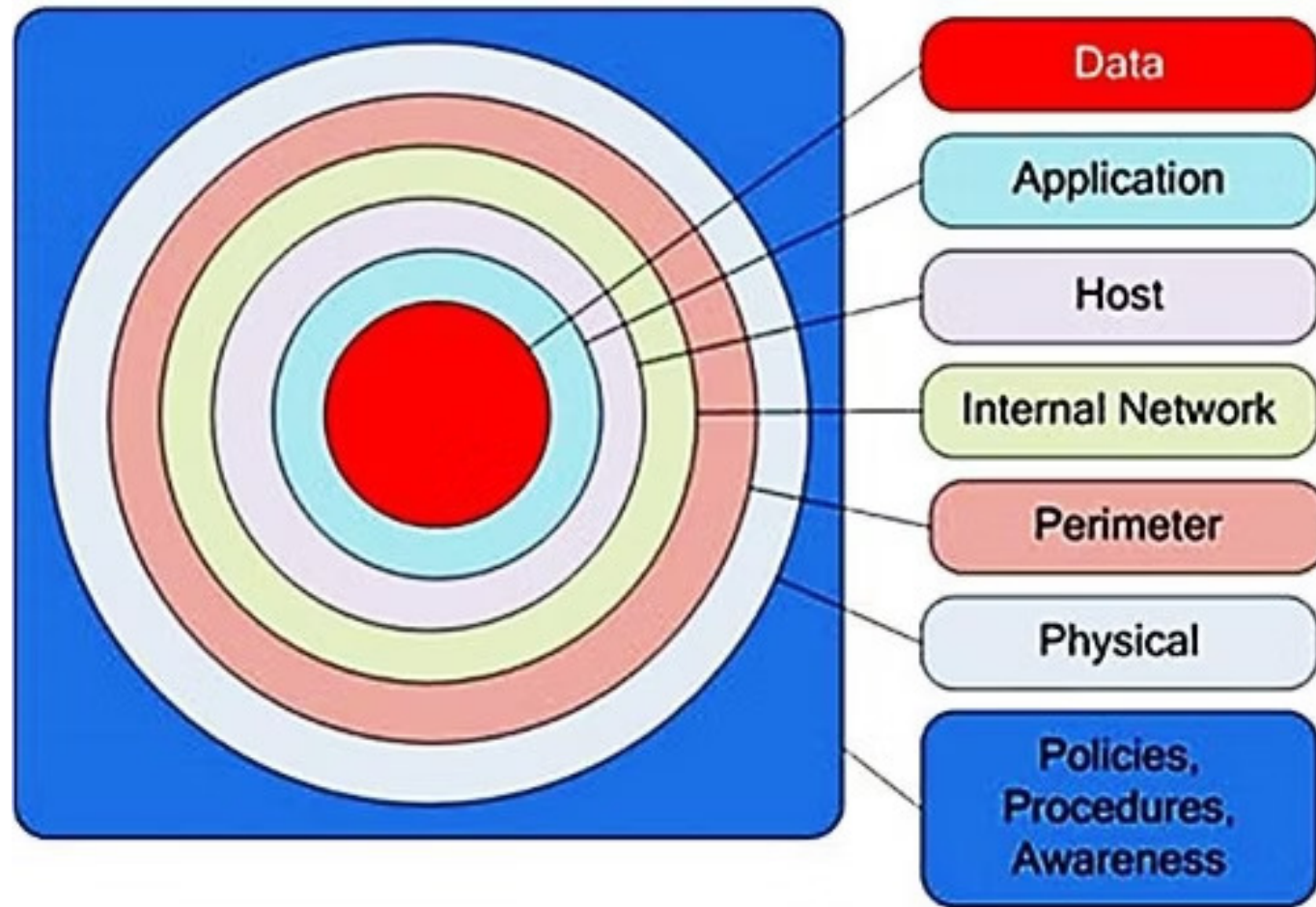
Seamless, frictionless access maximizes user satisfaction but may sacrifice **security** rigor and require expensive **convenience-security technologies**.

Model for Ensuring Information Systems Security

Seven-Layer Security Model

The seven-layer **security model** provides a structured approach to implementing **Defence in Depth**, ensuring comprehensive coverage across all aspects of **information security** from organizational **governance** to individual **data** elements.

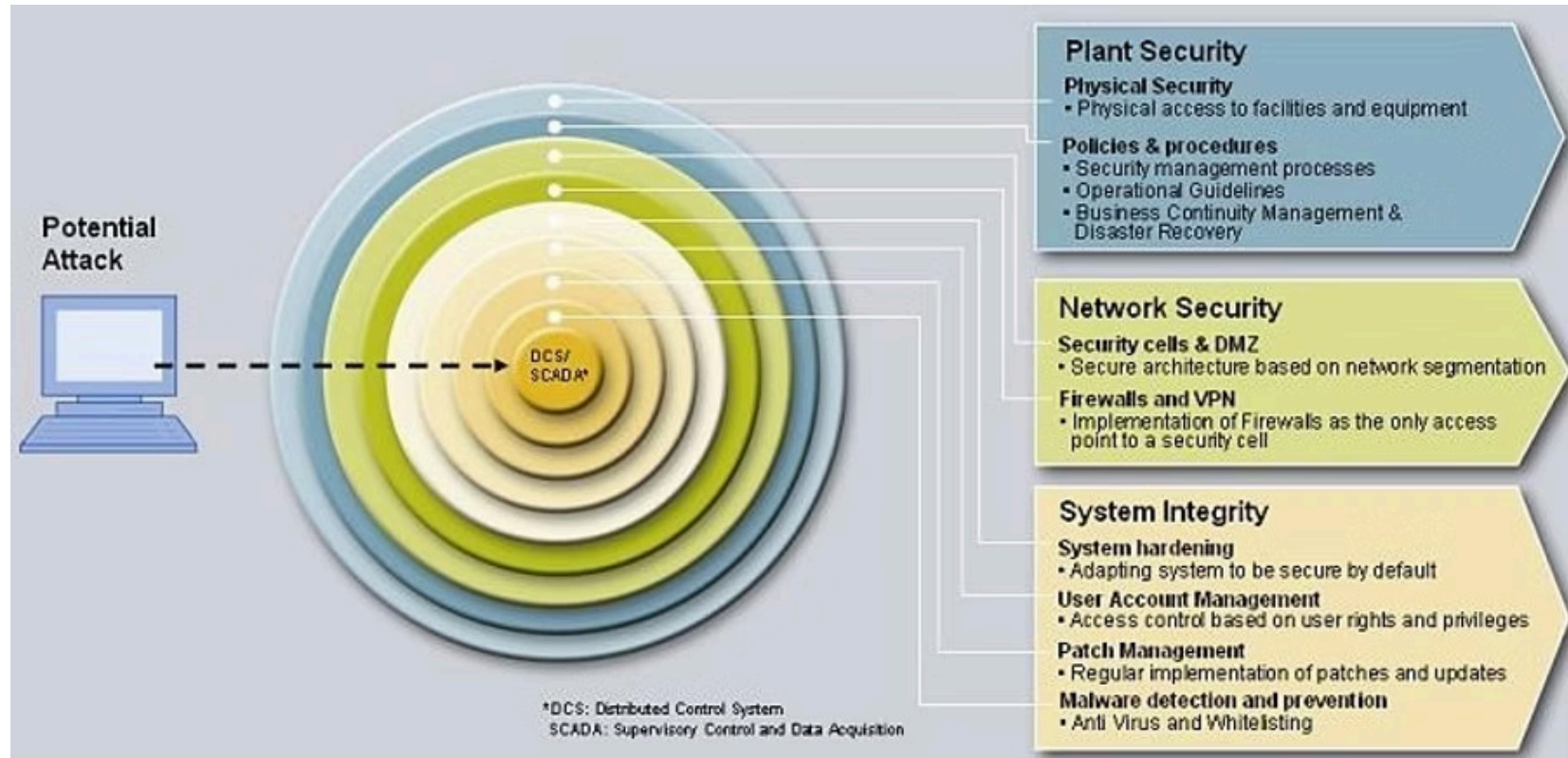
Policies, Procedures, Awareness Foundational governance establishing security objectives , acceptable use standards , and compliance requirements
Physical Securing facilities, hardware, and physical access through guards, locks, badges, and surveillance systems
Perimeter Boundary defenses including firewalls , intrusion detection , and DMZ networks protecting against external threats
Internal Network segmentation , access control lists , and monitoring protecting communications between internal systems
Host Operating system hardening , endpoint protection , and patch management securing individual devices
Application Secure coding practices , input validation , authentication mechanisms protecting software functionality
Data Encryption , access controls , and data loss prevention protecting information assets at rest and in transit



Seven-Layer Information Security Model

Three-Layer Security Model

The **three-layer model** provides a simplified yet comprehensive framework for **security architecture**, grouping **controls** into **organizational**, **network**, and **system** categories. This model facilitates **security planning** and **resource allocation** across organizational units.



Three-Layer Information Security Model

Security Layer	Sub-Layer	Description / Function
Plant Security (Organizational Security)	Physical Security	Controls physical access to system and network equipment.
	Policies & Procedures	Includes information security management processes, operational guidelines, business continuity management , and incident recovery procedures.
Network Security	Security Cells and DMZ	Provides protection mechanisms for segmented network zones .
	Firewalls and VPN	Acts as a controlled gateway and single entry point to network segments .
System Integrity	System Hardening	Ensures secure installation and configuration of system components according to security requirements .
	User Account Management	Implements access control based on user roles and privileges .
	Patch Management	Regularly installs security patches and system updates.
	Malware Detection and Prevention	Protects systems against viruses and other malicious software .

Key Takeaways

Essential Concepts in Information Systems Security

As we conclude this comprehensive overview of **information systems security**, several critical concepts emerge as foundational to understanding and implementing effective **security programs** in modern organizations.

CIA Triad Foundation Confidentiality, Integrity, and Availability form the bedrock of all security decisions. Every security control, security policy, and architecture must support these principles to effectively protect organizational assets.	Multi-Layer Defense Defence in Depth recognizes that no single security control is sufficient. Layered security provides redundant protection, ensures attackers must breach multiple barriers, and enables detection at multiple points.
Domain-Specific Risks Each IT infrastructure domain presents unique vulnerabilities requiring tailored protection strategies. Comprehensive security addresses all domains systematically rather than focusing narrowly on single areas.	Balanced Security Effective security requires balancing protection strength, implementation costs, and system usability. Organizations must make informed trade-offs based on risk tolerance and business requirements.

The Role of Security Professionals

Diverse Career Paths in Information Security

The **information security** field offers diverse career opportunities requiring different skill sets, from highly technical roles to strategic management positions. As **cyber threats** continue evolving and **regulatory requirements** expand, demand for qualified **security professionals** significantly exceeds supply.



Security Analyst

Monitors systems, investigates **incidents**, analyzes **threats**, and recommends **protective measures** based on current **threat landscapes**



Penetration Tester

Simulates **attacks** to identify **vulnerabilities** before malicious actors exploit them, testing **defenses** and recommending improvements



Security Architect

Designs comprehensive **security frameworks**, selects technologies, and ensures technical implementations align with **security requirements**



Compliance Officer

Ensures organizational adherence to **regulatory requirements**, **industry standards**, and internal **policies** through **audits** and assessments



Incident Responder

Leads **incident response** to **security breaches**, coordinates **containment** efforts, conducts **forensic analysis**, and restores normal operations



Security Manager

Oversees **security programs**, manages teams, allocates resources, and communicates **security posture** to executive leadership

Review Questions

1. What is **Information Security**?
2. Why is it necessary to ensure **information security**?
3. What are the fundamental **components of Information Security**?
4. How is **Information Assurance** typically implemented?
5. What is **Information Systems Security**?
6. What are the key **security requirements** for **information** and **information systems**?
7. What are the **threats** and **risks** in the **User Domain** and **Workstation Domain** within **IT infrastructure**? Why is the **User Domain** considered the most **vulnerable** and **high-risk** domain?
8. What are the **threats** and **risks** in the **LAN Domain**, **LAN-to-WAN Domain**, and **WAN Domain** within **IT infrastructure**? Why is the **WAN Domain** highly exposed to **destructive attacks**?
9. What is the general model for ensuring **Information Systems Security**?
10. Describe a general model for ensuring **Information Systems Security**.